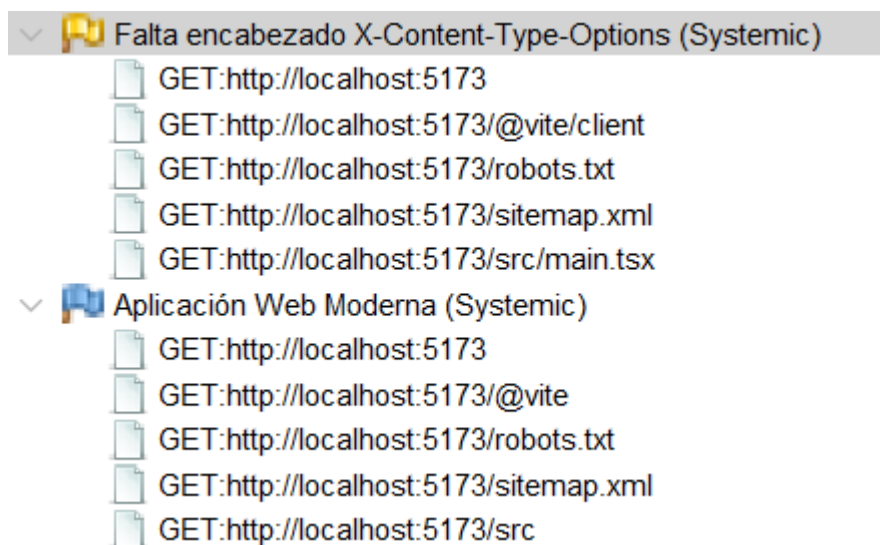


Informe de Pruebas de Seguridad — OWASP ZAP Sistema de Gestión de Citas

URL analizada: <http://localhost:5173> Tipo de escaneo: Pasivo automatizado

Introducción

Se realizó un análisis de seguridad sobre la aplicación web del sistema de gestión de citas de Piedrazul utilizando OWASP ZAP en su modalidad de escaneo pasivo automatizado. El objetivo fue identificar vulnerabilidades presentes en la aplicación web conforme a la especificación OWASP Top 10. A continuación se presentan las dos vulnerabilidades identificadas durante el análisis.



Vulnerabilidad 1 — Falta de encabezado X-Content-Type-Options

Clasificación OWASP Top 10: A05:2021 — Security Misconfiguration Nivel de riesgo: Low
Confianza: Medium CWE ID: 693 WASC ID: 15 URL afectada: <http://localhost:5173> y rutas derivadas (@vite/client, robots.txt, sitemap.xml, src/main.tsx)

Descripción: La cabecera HTTP X-Content-Type-Options no se encuentra configurada con el valor nosniff en las respuestas del servidor. Esta cabecera indica al navegador que no debe intentar inferir el tipo de contenido de una respuesta HTTP cuando el servidor ya ha declarado uno explícitamente. Su ausencia permite que navegadores antiguos o configuraciones especiales realicen MIME-sniffing sobre el cuerpo de la respuesta, lo que puede provocar que contenido malicioso sea interpretado y ejecutado con un tipo de contenido distinto al declarado. Esto abre la puerta a ataques de inyección de contenido en respuestas de error como 401, 403 o 500.

Evidencia encontrada por ZAP: El parámetro x-content-type-options no está presente en los encabezados de respuesta HTTP de ninguna de las rutas analizadas del frontend.

Remediación sugerida: Configurar el encabezado X-Content-Type-Options: nosniff en todas las respuestas del servidor. En el backend NestJS esto se resuelve instalando el middleware helmet con el comando `npm install @nestjs/helmet` y agregando

app.use(helmet()) en el archivo main.ts antes del método listen. Para el frontend estático desplegado en Render, se puede configurar este encabezado desde el panel de headers del servicio.

Falta encabezado X-Content-Type-Options

URL: http://localhost:5173

Riesgo:  Low

Confianza: Medium

Parámetro: x-content-type-options

Ataque:

Evidencia:

CWE ID: 693

WASC ID: 15

Origen: Pasivo (10021 - Falta encabezado X-Content-Type-Options)

Vector de Entrada:

Descripción:

La cabecera Anti-MIME-Sniffing X-Content-Type-Options no se ha establecido en 'nosniff'. Esto permite que las versiones anteriores de Internet Explorer y Chrome realicen MIME-sniffing en el cuerpo de la respuesta, lo que puede provocar que el cuerpo de la respuesta se interprete y se muestre como un tipo de contenido distinto del tipo de contenido declarado. Las versiones actuales (principios de 2014) y heredadas de Firefox utilizarán el tipo de contenido declarado (si se establece uno), en lugar de realizar MIME-sniffing.

Otra información:

Este problema aún se aplica a las páginas de tipo error (401, 403, 500, etc.), ya que esas páginas a menudo se ven afectadas por problemas de inyección, en cuyo caso aún existe la preocupación de que los navegadores husmeen las páginas lejos de su tipo de contenido real. En el umbral «Alto» esta regla de análisis no alertará sobre respuestas de error del cliente o servidor.

Solución:

Asegúrese de que la aplicación/servidor web establece el encabezado Content-Type adecuadamente, y que establece el encabezado X-Content-Type-Options a 'nosniff' para todas las páginas web. Si es posible, asegúrese de que el usuario final utiliza un navegador web moderno y compatible con los estándares que no realiza MIME-sniffing en absoluto, o que puede ser dirigido por la aplicación web/servidor web para que no realice MIME-sniffing.

Referencias:

[https://learn.microsoft.com/en-us/previous-versions/windows/Internet-explorer/4a4b2a41\(v=vs.85\)](https://learn.microsoft.com/en-us/previous-versions/windows/Internet-explorer/4a4b2a41(v=vs.85))

Vulnerabilidad 2 — Aplicación Web Moderna detectada sin exploración completa

Clasificación OWASP Top 10: A05:2021 — Security Misconfiguration (configuración de escaneo) Nivel de riesgo: Informational Confianza: Medium Origen: Pasivo 10109 — Aplicación Web Moderna URL afectada: <http://localhost:5173>

Descripción: OWASP ZAP detectó que la aplicación corresponde a una SPA (Single Page Application) moderna construida con React y Vite, lo cual se evidencia por la presencia de scripts del tipo module que inyectan hooks de recarga en caliente (@react-refresh). Este tipo de aplicaciones no generan enlaces HTML tradicionales que el spider estándar de ZAP pueda rastrear, lo que limita la cobertura del escaneo pasivo. La ausencia de enlaces rastreables significa que rutas protegidas por autenticación JWT, como los endpoints / citas, /medicos, /pacientes y /configuracion, no fueron analizadas en esta prueba por requerir token de acceso válido.

Implicación de seguridad: Las rutas protegidas del backend NestJS que requieren token JWT y validación de rol no son accesibles sin autenticación, lo cual es un comportamiento correcto y esperado. Sin embargo, esta configuración impide que ZAP realice un análisis activo completo sobre los endpoints de la API REST. Para un análisis más profundo en una etapa posterior se recomienda usar el Ajax Spider de ZAP o configurar un contexto de autenticación que permita a ZAP obtener un token JWT válido antes del escaneo.

Remediación sugerida: Para análisis futuros más completos, utilizar el módulo Ajax Spider de OWASP ZAP en lugar del spider estándar, ya que este es capaz de interactuar con aplicaciones JavaScript modernas. Adicionalmente, configurar un contexto de autenticación en ZAP con las credenciales de prueba para que pueda analizar los endpoints protegidos del backend.

Aplicación Web Moderna

URL:

http://localhost:5173

Riesgo:

 Informational

Confianza:

Medium

Parámetro:

Ataque:

Evidencia:

```
<script type="module">import { injectIntoGlobalHook } from "@react-refresh";
injectIntoGlobalHook(window);
window.$RefreshReg$ = () => {};
window.$RefreshSig$ = () => (type) => type;</script>
```

CWE ID:

WASC ID:

Origen:

Pasivo (10109 - Aplicación Web Moderna)

Vector de Entrada:

Descripción:

La aplicación parece ser una aplicación web moderna. Si necesita explorarla automáticamente, el Ajax Spider puede ser más eficaz que el estándar.

Otra información:

No se han encontrado enlaces aunque sí scripts, lo que indica que se trata de una aplicación web moderna.

Solución:

Se trata de una alerta informativa, por lo que no es necesario realizar ningún cambio.

Resumen de hallazgos

Vulnerabilidad	Categoría OWASP Top 10	Riesgo	Estado
Falta encabezado X-Content-Type-Options	A05 - Security Misconfiguration	Low	Identificada, remediación pendiente
Aplicación Web Moderna sin cobertura completa	A05 - Security Misconfiguration	Informational	Identificada, requiere configuración adicional de ZAP

Conclusión

El análisis con OWASP ZAP sobre la aplicación web de Piedrazul identificó dos alertas relevantes. La más importante desde el punto de vista de remediación es la ausencia del encabezado X-Content-Type-Options, que corresponde a una configuración de seguridad básica recomendada para toda aplicación web y cuya corrección es sencilla mediante el uso del middleware helmet en NestJS. La segunda alerta es de carácter informativo y refleja una limitación del escaneo pasivo frente a SPAs modernas, no una vulnerabilidad explotable en sí misma. Para un entorno de producción real se recomienda complementar este análisis con un escaneo activo autenticado y una revisión manual de los endpoints críticos del backend.